

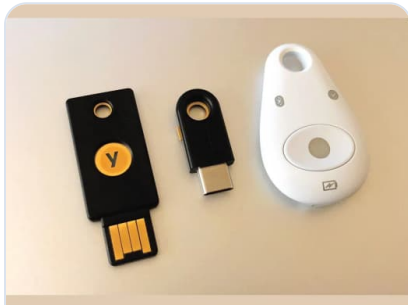
FONDAMENTAUX DE LA CYBERSÉCURITÉ

Guide du TP 2 : auditer des mots de passe et des comptes

TP 2 · Auditer des mots de passe

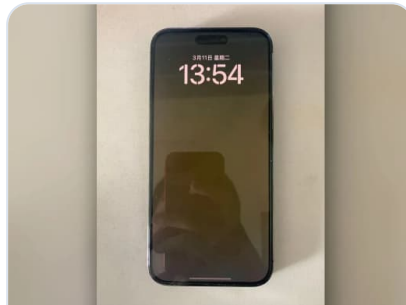


MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



Clé de sécurité matérielle (FIDO2)

Prouve ton identité, résiste à l'hameçonnage



Smartphone

Messages, photos, argent mobile et codes



Ordinateur portable

L'ordinateur que l'on emporte partout

Photos issues de Wikimedia Commons : Clé de sécurité matérielle (FIDO2), Tony Webster, CC BY 2.0 · Smartphone, 茅野ふたば, CC BY-SA 4.0 · Ordinateur portable, Ahunt, CC0.

CADRE ET LIMITES

- ◆ Toutes les données de ce laboratoire sont fictives.
- ◆ N'essaie rien sur un vrai service et ne teste jamais de vrais mots de passe sur Internet.
- ◆ Le dictionnaire fourni ne sert qu'à hacher des mots fictifs du labo.



Démarche

- 1 Lis l'inventaire des comptes : privilèges, double authentification, ancienneté du mot de passe.
- 2 Hache ensuite les entrées du dictionnaire avec SHA-256.
- 3 Compare les empreintes en hexadécimal, caractère pour caractère.
- 4 Priorise enfin les comptes critiques selon la règle : administrateur sans double authentification et mot de passe retrouvé.



Commandes utiles

◆ PowerShell 5.1 ou 7

POWERSHELL

```
$sha = [Security.Cryptography.SHA256]::Create()
Get-Content "fond-tp2-dictionnaire-fictif.txt" | ForEach-Object {
    $mot = $_.Trim()
    if ($mot) {
        $bytes = [Text.Encoding]::UTF8.GetBytes($mot)
        $empreinte = ([BitConverter]::ToString($sha.ComputeHash($bytes))).Replace('-', '').ToLower()
        "{0} {1}" -f $empreinte, $mot
    }
} | Set-Content "fond-tp2-dictionnaire-hache.txt"
Select-String -Path "fond-tp2-dictionnaire-hache.txt" -Pattern '^[0-9a-f]{64}\s{2}.\+$'
```

◆ Git Bash ou Linux avec sha256sum

BASH

```
while IFS= read -r mot; do
    [ -n "$mot" ] || continue
    empreinte=$(printf '%s' "$mot" | sha256sum | cut -d' ' -f1)
    printf '%s %s\n' "$empreinte" "$mot"
done < fond-tp2-dictionnaire-fictif.txt > fond-tp2-dictionnaire-hache.txt
grep -E '^[0-9a-f]{64} .+$' fond-tp2-dictionnaire-hache.txt | head -n 3
```

◆ OpenSSL, utile si sha256sum n'est pas disponible

BASH

```
while IFS= read -r mot; do
    [ -n "$mot" ] || continue
    empreinte=$(printf '%s' "$mot" | openssl dgst -sha256 -r | awk '{print $1}')
    printf '%s %s\n' "$empreinte" "$mot"
done < fond-tp2-dictionnaire-fictif.txt > fond-tp2-dictionnaire-hache.txt
head -n 3 fond-tp2-dictionnaire-hache.txt
```

◆ Variante téléphone ou navigateur

Si tu n'as qu'un téléphone, tu peux utiliser un outil de hachage en ligne uniquement avec les mots fictifs du labo, jamais avec un vrai mot de passe.



Rechercher ensuite une empreinte

Une fois le fichier `fond-tp2-dictionnaire-hache.txt` créé, relève une empreinte dans l'extrait puis cherche la même suite hexadécimale au début d'une ligne. Le mot placé après les deux espaces est le candidat associé.



Repères utiles

- ◆ Pour une phrase de passe de plusieurs mots, utilise la formule : $\text{nombre_de_mots} \times \log_2(\text{taille_de_la_liste})$.
- ◆ Pour un essai exhaustif théorique, pars de $\text{charset}^{\text{longueur}}$ puis divise par la vitesse d'essais par seconde et par 3600 pour obtenir des heures.
- ◆ Une empreinte hexadécimale se compare caractère par caractère, sans espace ajouté ni supprimé.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).